

LoftDesign - Security Audit Report

Comprehensive listing of implemented security measures and identified gaps

Generated: 2026-06-07

29 implemented measures | 11 gaps identified

Implemented Security Measures

#	Category	Measure	Details	Files / Line
1	Authz - Role-Based	@role_required decorator	Checks UserProfile.role against allowed roles; superusers bypass	dashboard/decorator.py:25
2	Authz - Admin-Only	@admin_required decorator	Requires is_superuser	dashboard/decorator.py:8
3	Authz - Login Gate	@login_required	Django built-in, used on dashboard home	dashboard/views/dashboard.py:11
4	Authz - Channel auth	NotificationChannelManager	Users can only read their own user-{id} channel	dashboard/channelmanager.py:13
5	Authz - Blocked check	Login rejects blocked accounts	Checks profile.is_blocked during login	user_auth/views.py:51
6	Authz - POST guard	@require_POST	Cart endpoints accept POST only	frontend/views/cart.py:70,109,146
7	Authn - Password hashing	PBKDF2-SHA-256 (Django default)	Not overridden	-

#	Category	Measure	Details	Files / Line
9	Authn - Password reset	PasswordResetTokenGenerator urlsafe_base64_decode	+ Secure token in URL	user_auth/views.py:159,297
10	Authn - Set unusable password	Admin-created providers get no password	Uses set_unusable_password(); must use token flow	dashboard/views/users.py:59
11	Authn - Inactive on create	New affiliates are is_active=False until approval	Admin must approve before login allowed	user_auth/utlis.py:60
12	CSRF	CsrfViewMiddleware enabled	All 35+ forms include {% csrf_token %}	core/settings.py:65
13	CSRF	CSRF_TRUSTED_ORIGINS from env	Loaded via decouple.config()	core/settings.py:187

#	Category	Measure	Details	Files / Line
15	XSS	escapejs for JS context	Used for user data in <script> blocks	frontend/templates/index.html:18
16	XSS	safe restricted	Only used on trusted json.dumps() data (3 instances)	dash_home.html:58
17	Clickjacking	XFrameOptionsMiddleware	Sends X-Frame-Options: DENY	core/settings.py:68
18	SQLi	ORM-only queries	No raw(), cursor(), connection.execute anywhere	-
19	Secrets	python-decouple	All secrets loaded from .env via config()	core/settings.py:14
20	Secrets	.env in .gitignore	Prevented from being committed	.gitignore:3

#	Category	Measure	Details	Files / Line
22	HTTPS	Nginx 301 redirect	HTTP to HTTPS at proxy level	nginx/nginx.conf:13
23	HTTPS	Let's Encrypt + Certbot	Auto-renewal every 12h	docker-compose.yml:70
24	Uploads	Upload path sanitisation	user_profile_upload_path extracts only extension	user_auth/utlis.py:78
25	Integrity	transaction.atomic()	10+ critical ops wrapped in atomic transactions	dashboard/views/users.py:47
26	Integrity	Email failure rolls back	Provider/affiliate creation rolls back on email failure	dashboard/views/users.py:96
27	Debug	DEBUG = False in production	Controlled by APP_ENV env var	core/settings.py:33

#	Category	Measure	Details	Files / Line
---	----------	---------	---------	--------------

29

Static files	Whitenoise	Secure static file serving	core/settings.py:61
--------------	------------	----------------------------	---------------------

Gaps & Recommendations

#	Gap	Severity	Details
1	No rate limiting / brute-force protection	HIGH	Login, password reset, signup endpoints are all unprotected
2	No session/CSRF cookie security attributes	HIGH	SESSION_COOKIE_SECURE, CSRF_COOKIE_SECURE not set; cookies may be sent over HTTP in production
3	No file extension/type validation on uploads	MEDIUM	Users can upload any file type via ImageField / FileField
4	No CORS configuration	MEDIUM	No django-cors-headers; API accessible cross-origin
5	No security headers beyond defaults	MEDIUM	No HSTS, X-Content-Type-Options, Content-Security-Policy at Django or Nginx level
6	No Django Forms	MEDIUM	All validation is manual in views; no central form validation
7	Extremely large upload limits (1.2 GB)	LOW-MEDIUM	DATA_UPLOAD_MAX_MEMORY_SIZE & FILE_UPLOAD_MAX_MEMORY_SIZE create DoS surface
8	validate_algerian_phone never called	LOW	Phone validation function exists but is unused in any view

#	Category	Measure	Details	Files / Line
9		Default admin password in .env	LOW	ADMIN_PASSWORD=adminpassword; APP_SECRET is a non-production placeholder
10		No SECURE_SSL_REDIRECT	LOW	HTTPS redirect is only at Nginx level - Django itself doesn't enforce it
11		Semi-affiliate password min 6 chars	LOW	Inconsistent with rest of app which uses min 8 chars